

ZADANIE 2: Plan Audytu Sieci Komputerowej

1. Zakres i cele audytu

W zakresie:

- 20 stacji roboczych (10 Biuro, 3 IT, 4 Management, 3 Remote)
- 3 serwery (File, App, DB)
- Komponenty Zero Trust (Policy Engine, Identity Server, SIEM)
- Perimeter (Firewall, VPN Gateway)

Poza zakresem:

- Systemy zewnętrznych dostawców (SaaS)
- Fizyczna kontrola dostępu do serwerowni

Pytania kluczowe:

- Czy architektura Zero Trust jest skutecznie wdrożona?
- Czy dostęp do zasobów jest odpowiednio kontrolowany?
- Czy monitorowanie wykrywa anomalie?
- Czy konfiguracje są zgodne z polityką bezpieczeństwa?

2. Analiza ryzyka

Zasób	Krytyczność	Główne ryzyko
DB Server	KRYTYCZNA	Wyciek danych, brak szyfrowania, nadmierne uprawnienia
Identity Server (AD/LDAP)	KRYTYCZNA	Kompromitacja kont, brak MFA, słabe hasła
File Server	WYSOKA	Nieautoryzowany dostęp, brak backupu, ransomware
SIEM/Monitor	WYSOKA	Brak alertów, luki w logowaniu
Management workstations	WYSOKA	Phishing, brak separacji kont admin

VPN Gateway	ŚREDNIA	Słabe protokoły, brute-force
Policy Engine (NAC)	ŚREDNIA	Błędna konfiguracja reguł
IT workstations	ŚREDNIA	Nadużycie uprawnień
Biuro/Remote workstations	NISKA	Endpoint standardowy

3. Kontrole i testy

A. Zero Trust Architecture

Policy Engine (NAC):

- **Test:** Próba połączenia urządzenia niezarejestrowanego → oczekiwane: odmowa
- **Test:** Weryfikacja reguł dostępu dla każdej roli (Biuro, IT, Management, Remote)
- **Dowód:** Logi NAC, screenshot reguł, test penetracyjny

Identity Server:

- **Test:** Weryfikacja polityki haseł (zgodność z NIST SP 800-63B)
- **Test:** Sprawdzenie wymuszonego MFA dla Remote i Management
- **Test:** Audyt kont nieaktywnych >90 dni
- **Dowód:** Raport z AD (Get-ADUser), logi uwierzytelniania

SIEM/Monitor:

- **Test:** Symulacja ataku (failed login x10) → sprawdzenie alertu
 - **Test:** Weryfikacja źródeł logów (wszystkie serwery, firewalle, endpoints)
 - **Dowód:** Dashboard SIEM, przykładowe alerty, coverage matrix
-

B. Serwery

File Server:

- **Test:** Przegląd uprawnień NTFS (zasada least privilege)
- **Test:** Weryfikacja backupu (last successful backup <24h)
- **Test:** Test odtworzenia pliku z backupu
- **Dowód:** Raport z `icacls`, logi backupu, screenshot testu restore

App Server:

- **Test:** Skan podatności (Nessus/OpenVAS)
- **Test:** Weryfikacja patchingu (updates <30 dni)

- **Test:** Przegląd otwartych portów (tylko niezbędne)
- **Dowód:** Raport ze skanera, lista zainstalowanych updateów, `netstat -an`

DB Server:

- **Test:** Sprawdzenie szyfrowania (data at rest + in transit)
 - **Test:** Audyt kont DB (brak default passwords, są wyłączone)
 - **Test:** Przegląd logów dostępu (kto, kiedy, do czego)
 - **Dowód:** Konfiguracja TDE/SSL, lista userów DB, query log sample
-

C. Perimeter

Firewall:

- **Test:** Review reguł (usunięcie zbędnych, zasada deny-all na końcu)
- **Test:** Weryfikacja logowania (wszystkie deny logowane)
- **Test:** Test zewnętrzny port scan
- **Dowód:** Firewall rule export, logi, raport Nmap

VPN Gateway:

- **Test:** Weryfikacja protokołów (IKEv2/OpenVPN, brak PPTP)
 - **Test:** Sprawdzenie MFA przy połączeniu VPN
 - **Test:** Przegląd active sessions (nie ma podejrzanych)
 - **Dowód:** Konfiguracja VPN, logi połączeń, test connect
-

D. Endpoints (stacje robocze)

Wszystkie grupy (Biuro, IT, Management, Remote):

- **Test:** Compliance check wg baseline z Zadania 1
- **Test:** Weryfikacja agenta EDR (aktywny, aktualna wersja)
- **Test:** Sample check: BitLocker, Firewall, Antivirus status
- **Dowód:** Raport z PowerShell skryptu, dashboard EDR

Management (4 stacje):

- **Test dodatkowy:** Weryfikacja separacji kont (brak codziennego logowania na admin)
- **Dowód:** Logon logs z ostatnich 30 dni

Remote (3 stacje):

- **Test dodatkowy:** Wymuszony VPN przed dostępem do zasobów
 - **Dowód:** Logi Policy Engine, test połączenia spoza VPN
-

4. Wykonanie audytu

Harmonogram (7 dni roboczych):

Dzień	Działanie	Odpowiedzialny
1	Kick-off meeting, zbieranie dokumentacji	Audytor główny + IT Manager
2-3	Testy infrastruktury (serwery, perimeter, Zero Trust)	Audytor + Tech Audytor
4	Testy endpoints (sample 30% stacji z każdej grupy)	Tech Audytor
5	Testy penetracyjne (symulacja ataku zewnętrznego)	Pentester zewnętrzny
6	Analiza wyników, identyfikacja luk	Audytor główny
7	Przygotowanie raportu	Audytor główny

Narzędzia:

- **Skanery:** Nessus, OpenVAS
- **Network:** Wireshark, Nmap
- **AD Audit:** BloodHound, PingCastle
- **Compliance:** Microsoft SCCM, CIS-CAT
- **SIEM:** Dostęp do Splunk/ELK/QRadar
- **Pentesting:** Metasploit, Burp Suite (tylko w kontrolowanym środowisku)

Zasady bezpieczeństwa podczas testów:

1. Wszystkie testy penetracyjne tylko po pisemnej zgodzie Management
2. Testy destrukcyjne (DoS, eksploity) → **NIE**
3. Testy produkcyjne po godzinach (18:00-22:00) dla krytycznych systemów
4. Backup przed testami na DB Server
5. Audytor pracuje z konta oddzielnego (nie admin domenowy)

5. Raportowanie

Raport techniczny (dla IT):

- Szczegółowa lista znalezionych luk (CVE, CVSS score)
- Kroki reprodukcji problemu
- Zalecenia remediacyjne (konkretne komendy/zmiany konfiguracji)

- Timeline: co naprawić najpierw

Raport zarządczy (dla Management):

- Executive Summary (1 strona)
- Poziom ryzyka w skali (Niskie/Średnie/Wysokie/Krytyczne)
- Top 5 zagrożeń + wpływ biznesowy
- Wykres: % zgodności z polityką
- Koszt i czas remediation (oszacowanie)

Metryki:

- Liczba znalezionych luk (breakdown: Critical/High/Medium/Low)
- Compliance rate (% spełnionych kontroli)
- Mean Time to Patch (MTTP)
- Liczba kont z nadmiernymi uprawnieniami

Dostawa:

- Raport techniczny: PDF + Excel z detalami
- Raport zarządczy: PowerPoint (max 15 slajdów)
- Termin: 3 dni po zakończeniu audytu
- Prezentacja wyników: Meeting z IT + Management (1h)

Podsumowanie

Audyt obejmuje **7 obszarów krytycznych** w modelu Zero Trust, z **naciskiem na Identity, Policy Engine i SIEM** jako fundament bezpieczeństwa. Każda kontrola ma jasno określony test i oczekiwany dowód (pass/fail). Ryzyko jest posegregowane wg krytyczności zasobów. Raportowanie dostosowane do odbiorcy (techniczna głębia dla IT, biznesowy język dla Management).